Semana 06 — Instrumentar la linea base y clasificar alertas

Grupo 1 · rol Púrpura · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	06 de 10
Fase	3 — Defensa y hardening
Grupo	1
Rol	Púrpura
Entrega	GitHub, carpeta semana_06/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos.

- Instrumentar el evento, activando el registro que lo vería y definiendo la alerta con su umbral.
- Comparar lo que se registró con lo que se ejecutó, ítem por ítem del paso a paso.
- Reportar falsos positivos y negativos y proponer el ajuste concreto de la regla.

2 Qué aporta este rol al entregable

La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

3 Ejemplo paso a paso

El rol Púrpura mide antes y despues con el mismo auditor, y convierte las alertas de Suricata en una tabla con decision. Una alerta sin clasificar no es deteccion.

3.1 Capturar doce controles antes de cambiar nada

El auditor recorre los doce controles y emite un veredicto por cada uno. Se ejecuta antes del hardening para que la comparacion tenga sentido.

```
mkdir -p semana_06/evidencia
cat > semana_06/auditor.sh <<'SH'
#!/bin/sh
echo "usuario_root_ssh: $(sshd -T 2>/dev/null | awk '/^permitrootlogin
    /{print $2}')"
echo "password_auth: $(sshd -T 2>/dev/null | awk '/^
    passwordauthentication/{print $2}')"
echo "suid_total: $(find / -perm -4000 -type f 2>/dev/null | wc -l)"
echo "world_writable: $(find / -xdev -type f -perm -0002 2>/dev/null |
    wc -l)"
echo "puertos_escucha: $(ss -tulpn 2>/dev/null | grep -c LISTEN)"
echo "ufw: $(ufw status 2>/dev/null | head -1)"
SH
chmod +x semana_06/auditor.sh
sudo semana_06/auditor.sh | tee semana_06/evidencia/antes.txt
```

3.2 Ejecutar el hardening y repetir el auditor

Los cambios se aplican con comandos reproducibles y se recargan los servicios. El auditor se repite sin modificarlo: la unica variable es el sistema.

```
sudo sed -i -E 's/^#?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/
    sshd_config
sudo sed -i -E 's/^#?PasswordAuthentication.*/PasswordAuthentication no
    /' \
  /etc/ssh/sshd_config
sudo sshd -t && sudo systemctl reload ssh 2>/dev/null || sudo kill -HUP
    1
sudo ufw default deny incoming
sudo ufw allow 2222/tcp
sudo ufw --force enable
sudo semana_06/auditor.sh | tee semana_06/evidencia/despues.txt
```

3.3 Leer y clasificar las alertas de Suricata

Se extraen las alertas de la ventana de pruebas y se clasifican en verdaderas, esperadas y ruido. Cada clasificacion tiene un motivo escrito.

```
sudo suricata -T -c /etc/suricata/suricata.yaml 2>&1 | tail -3 \
  | tee semana_06/evidencia/suricata_check.txt
sudo python3 - <<'PY' | tee semana_06/evidencia/alertas.txt
import json
rutas = ['/var/log/suricata/eve.json']
for ruta in rutas:
    try:
        for linea in open(ruta, errors='ignore'):
            evento = json.loads(linea)
            if evento.get('event_type') == 'alert':
                print(evento['timestamp'], evento['alert']['signature
                    '])
    except FileNotFoundError:
        print('sin eve.json: se documenta como no verificado')
PY
```

3.4 Proponer una regla concreta

La regla cubre el ataque que la politica freno: repetir el escaneo y detectar el intento contra el puerto cerrado. Se escribe para el motor que ya esta en uso.

3.5 Control, umbral y accion

Control, umbral y accion

Control	Verificacion	Estado inicial	Umbral	Accion
Acceso de root por SSH	sshd -T	Permitido	Prohibido	Corregir
Autenticacion por contrasena	sshd -T	Habilitada	Deshabilitada	Corregir
Archivos SUID	find -perm -4000	Conteo base	Sin cambios no justificados	Revisar
Puertos en escucha	ss -tulpn	Conteo base	Solo los necesarios	Cerrar
Politica de filtrado	ufw status	Inactiva	Deny por defecto	Activar

El estado inicial se copia de antes.txt; si un control no se pudo medir, se marca como no verificado y se explica por que.

4 Qué guardar en el repositorio

Se entrega el auditor, las salidas antes y despues, la tabla de alertas clasificadas y la regla propuesta con su justificacion.

```
semana_06/
|-- informe.md
|-- auditor.sh
|-- evidencia/
|   |-- antes.txt
|   |-- despues.txt
|   |-- suricata_check.txt
|   `-- alertas.txt
`-- README.md
```

- El auditor es el mismo archivo antes y despues.
- Cada alerta tiene clasificacion y motivo.
- La regla propuesta se refiere a un ataque concreto observado.
- Las limitaciones de Suricata en el contenedor estan declaradas.

5 Cómo se corrige

Criterio	Peso
Doce controles documentados y verificables	2,0
Auditor funcional con veredicto por control	2,0
Política de filtrado correcta y sistema operativo	2,5
Alertas de Suricata clasificadas y regla propuesta	2,5
Antes/después comparables y justificación de excepciones	1,0
Total	**10,0**

- {'Recargar SSH puede cortar la sesion': 'se usa una sesion de consola separada.'}
- Si Suricata no arranca en el contenedor, se documenta y se evalua con las firmas disponibles.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.